



VULNERABILITY ASSESSMENT REPORT

On Virtual Card solution

Cybersecurity Department

September, 2026

Contents

1. Document Control	4
1.1 Version History	4
1.2 Distribution List	4
1.3 Document Classification	4
2. Executive Summary	6
3. Assessment Overview	7
3.1 Objectives	7
3.2 Scope	7
3.3 Assessment Types & Limitations	8
4. Summary of Findings	10
5. Detailed Findings	11
6. Remediation Roadmap	31
6.1 Prioritized Remediation Table	31
6.2 Remediation Guidance (Risk-based)	33
7. Conclusion	34
Appendices	35
Appendix A: Glossary of Terms	35
Appendix B: CVSS v3.1 Scoring Reference	36
Appendix C: Severity Classification Criteria	36

Organization:	NIB International Bank S.C
System / Application:	Virtual Card solution
Assessment Types:	SAST DAST SCA
Report Version:	v1.0
Department	Cybersecurity Department
Report Date:	18/09/2026
Classification:	CONFIDENTIAL
Tested By:	Ayenew
Reviewed By:	
Approved By:	

This document contains sensitive security information. Handle and store accordingly.

1. Document Control

1.1 Version History

Version	Date	Description of Changes
v1.0	6/06/2026	Initial Version

1.2 Distribution List

Name	Role / Title	Organization	Copy Type
Cybersecurity	CIO/Director	NIB International Bank	Electronic
EPMO	Director	NIB International Bank	Electronic

1.3 Document Classification

This document is classified as CONFIDENTIAL. It must not be distributed outside the defined distribution list without prior written approval from the document owner. All copies must be stored securely and destroyed when no longer required.

Disclaimer:

This security assessment was conducted within the approved assessment scope and designated assessment environment at the time of testing. The observations, findings, recommendations, and risk ratings presented in this report are based on the configuration, application behavior, and system state observed during the assessment period.

Responsibility for implementing, migrating, validating, and maintaining remediation actions, security configurations, patches, transport security controls, and version-controlled changes across all relevant environments, including production, remains with the respective application, infrastructure, middleware, and system owners through established change management, release management, and operational governance processes.

Any deviation between assessed environments and production environments may result in residual security risks outside the validation scope of this assessment.

2. Executive Summary

A Vulnerability Assessment was conducted on the Virtual Card solution application to evaluate its security posture ahead of production deployment. The assessment covered the application layer, APIs, source code, and supporting dependencies.

The assessment identified **15 security findings** across Critical, High, and Medium severities, indicating that while the application is functionally complete, several security gaps remain.

The most critical issue is a **file upload vulnerability and the first two of SCA vulnerabilities on detailed findings section** that could allow an attacker to potentially gain control of the underlying server, posing a serious risk of system compromise and data exposure.

Although no active exploitation was observed, the identified vulnerabilities increase exposure to risks such as unauthorized access, data leakage, service disruption, and reputational damage.

All Critical and High severity issues should be remediated before go-live, followed by mitigation of Medium and Low risks.

A follow-up validation and retesting exercise is recommended after remediation to confirm that all identified issues have been effectively addressed.

Assessment Scope Note:

This assessment reflects the security posture of the designated assessment environment at the time of testing. Production deployment integrity, release consistency, and operational security control enforcement remain the responsibility of the respective system and application owners.

3. Assessment Overview

3.1 Objectives

The primary objectives of this vulnerability assessment are:

- Identify security vulnerabilities across all in-scope systems and applications
- Assess the effectiveness of existing security controls and defensive measures
- Provide actionable remediation guidance prioritized by risk and business impact
- Validate compliance with applicable security standards and regulatory frameworks
- Establish a security baseline for continuous monitoring and future assessments

3.2 Scope

In-Scope

The assessment was conducted on the merchant application within the **test environment**, focusing primarily on application-level security controls.

Asset / Component	Type	URL / IP / Path	Notes
Virtual Card solution	Web Application	https://vctestminiapp.nibbank.com.et	Test environment
Source Code Repository	Source Code	VPCard	SAST target

Out-of-Scope

The following areas were excluded from the assessment:

- Production environment infrastructure and hardening (servers, OS, and network configurations)
- Third-party service provider internal systems not directly integrated with the application
- Social engineering attacks (phishing, impersonation, or user awareness testing)
- Mobile applications or client-side native applications (if any exist outside the web scope)
- External vendor or partner systems not explicitly included in the defined scope

3.3 Assessment Types & Limitations

Assessment Limitations

The assessment was performed within the approved assessment environment and agreed testing scope. The assessment results reflect the security posture of the assessed systems and components at the time of testing only.

Production environments, infrastructure configurations, middleware controls, deployment pipelines, and operational security controls were not independently validated as part of this engagement unless explicitly stated within scope.

Maintaining deployment consistency, secure configuration management, remediation implementation, and production operational integrity remains the responsibility of the respective application, infrastructure, and system owners through established governance and change management processes.

Assessment Type

Assessment Type	Description	Coverage / Target
SAST — Static Application Security Testing	Source code and binary analysis to detect vulnerabilities without execution. Reviews code quality, security anti-patterns, and hardcoded secrets.	VPCard source code
DAST — Dynamic Application Security Testing	Runtime testing of the running application through automated scanning and manual probing. Covers injection, authentication, authorization, and business logic flaws.	https://vctestminiapp.nibbank.com.et/login
SCA — Software Composition Analysis	Analysis of third-party and open-source library dependencies for known CVEs, license risks, and outdated versions.	package-lock.json

4. Summary of Findings

Assessment Type	Critical	High	Medium	Low	Info	Total
SAST	0	0	0	0	0	0
DAST	1	0	3	1	0	5
SCA	2	7	1	0	0	10
TOTAL	3	7	4	1	0	15

5. Detailed Findings

VA-001 — Critical Security Vulnerabilities in Next.js 16.3.2	
Finding ID	VA-001
Severity	Critical
CVSS v4.0 Score	Score: 9.1 (critical)
Assessment Type	SCA
Affected Asset / Component	next@16.3.2
CWE Reference	CWE-1038 – Insecure Automated Optimizations
CVE Reference	N/A
Status	Open
Description	
The application uses Next.js version 16.3.2, which is affected by two Critical security vulnerabilities. The first vulnerability involves insecure automated image optimization, where a specially crafted AVIF image processed through the Next.js Image Optimization API can reach a vulnerable sharp/libheif decoding path and potentially result in arbitrary code execution. The second vulnerability is a directory traversal issue in Next.js incremental cache handling that can allow crafted cache paths to escape the intended cache directory and, under specific Windows-hosted deployment conditions, potentially result in remote code execution. Both vulnerabilities affect next@16.3.2 and are fixed in next@16.3.3.	
Evidence / Proof of Concept	
Installed version is next@16.3.2	
Impact	
Successful exploitation of the identified vulnerabilities could result in remote code execution and compromise of the Next.js application server. The image optimization vulnerability may allow malicious AVIF content to trigger code execution through the server-side image processing path. The directory traversal	

vulnerability may allow an attacker to escape the intended cache directory and potentially manipulate or access server-side files, with the documented RCE scenario specifically affecting Windows-hosted deployments without Cache Components.

Recommendation

Upgrade next@16.3.2 → next@16.3.3 or higher

VA-002 — Multiple Security Vulnerabilities in Undici 7.29.0

Finding ID	VA-002
Severity	Critical
CVSS v4.0 Score	Score: 9.1 (critical)
Assessment Type	SCA
Affected Asset / Component	undici@7.29.0 package
CWE Reference	CWE-444 – HTTP Request/Response Smuggling CWE-197 – Numeric Truncation Error CWE-345 – Insufficient Verification of Data Authenticity CWE-772 – Missing Release of Resource after Effective Lifetime
CVE Reference	CVE-2026-18540 CVE-2026-84947 CVE-2026-85008 CVE-2026-18149
Status	Open

Description

The application uses undici@7.29.0, which is affected by multiple security vulnerabilities involving HTTP request smuggling, numeric truncation, insufficient verification of cached data, resource exhaustion, uncaught exceptions, persistent sensitive cookies, and improper TLS certificate validation. Depending on the application's use of Undici features such as retry, decompression, WebSocket, caching, and BalancedPool,

these vulnerabilities may allow attackers to cause denial of service, manipulate or poison responses, expose sensitive information, or bypass custom certificate validation. All identified vulnerabilities are addressed by upgrading Undici to version 7.29.1 or later.

Evidence / Proof of Concept

The installed package is undici@7.29.0.

Impact

Depending on the application's use of the affected Undici functionality, exploitation may result in denial of service through resource exhaustion or process crashes, HTTP response manipulation, cache poisoning or delivery of fabricated responses, exposure of sensitive cookies, or bypass of custom TLS certificate validation. The certificate-validation issue is particularly significant because it can allow a malicious certificate to be accepted when applications rely on custom checkServerIdentity or connector callbacks through BalancedPool.

Recommendation

Upgrade undici from 7.29.0 to 7.29.1 or later.

VA-003 — Unrestricted File Upload via Double Extension Bypass

Finding ID	VA-003
Severity	Critical
CVSS v4.0 Score	Score: 9.8 (critical) 3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Assessment Type	DAST
Affected Asset / Component	https://vctestminiapp.nibbank.com.et/
CWE Reference	CWE-434 CWE-646
CVE Reference	CVE-2017-9841 CVE-2021-41773 CVE-2023-50164

Open

The application is vulnerable to unrestricted file upload due to improper validation of uploaded file extensions. The server accepts files containing multiple extensions (double extensions), allowing an attacker to upload executable files disguised as legitimate content.

Evidence / Proof of Concept

```
8 Accept-Encoding: gzip, deflate, br
9 Referer: https://vctestinapp.nibbank.com.et/admin/customer-mapping
Content-Type: multipart/form-data; boundary=-----geckofoarabundSecd1c35e8d96395a52897f47457tllle
Content-Length: 16887
Origin: https://vctestinapp.nibbank.com.et
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin
Priority: u=4
Te: trailers
-----geckoforabundSecd1c35e8d96395a52897f47457tllle
Content-Disposition: form-data; name='file'; filename='customer-mapping-template [copy 1].exe.xlsx'
Content-Type: application/vnd.openxmlformats-officedocument.spreadsheetml.sheet
PKC:\ux\l_rels\workbook.xml.rels&xsl version='1.0' encoding=UTF-8 standalone=yes?>
</relationships> xsl:base xmlns:schema="http://schemas.openxmlformats.org/drawingml/2006/relationships#Relationship" Id="rId1" type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/worksheet Target="worksheets/sheet1.xl"/></Relationship Id="rId2" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/theme Target="theme/theme1.xl"/></Relationship Id="rId3" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/styles Target="styles.xml"/></Relationship Id="rId4" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/metadata Target="metadata.xml"/></Relationships PKC:\PDL\&t/home?the=xel.xml?xsl version='1.0' encoding=UTF-8 standalone=yes?>
<!--these values are http://schemas.openxmlformats.org/drawingml/2006/main name="Office Theme">a:thesethemeElements=a:d:k:Title name="Office">a:d:k:l val=sySrlCl val="WindowText" lastClr="000000"/>a:d:k:1:a:st:h name="window" lastClr="FFFFFF"/>a:dt:l:a:d:k:2:a:sgRblCr val="F49D07"/>a:dc:2:a:it:z:a:sgRblCr val="EEECED"/>a:it:z:a:acc:1:a:sgRblCr val="4B8BBE9A"/>a:cc:2:a:acc:2:a:sgRblCr val="CC5AD0A7"/>a:cc:2:a:acc:3:a:sgRblCr val="9EB85599"/>a:dc:2:a:acc:4:a:sgRblCr val="80644421"/>a:acc:4:a:acc:5:a:sgRblCr
```

- Remote Code execution
- Full server compromise
- Data breach
- Website defacement
- Malware distribution
- Denial of service
- Compliance and reputation damage

- Validate file extension strictly
- Validate MIME types
- Store uploads outside web roots
- Disable script Execution in upload directories

VA-004 — Regular Expression Denial of Service (ReDoS) in Tiptap Core

Finding ID	VA-004
Severity	High
CVSS v4.0 Score	Score: 8.7 (High)
Assessment Type	SCA
Affected Asset / Component	@tiptap/core@3.30.2, introduced through @tiptap/starter-kit@3.30.2
CWE Reference	CWE-1333 – Inefficient Regular Expression Complexity
CVE Reference	N/A
Status	Open
Description	
The application uses @tiptap/core version 3.30.2, which is affected by a Regular Expression Denial of Service (ReDoS) vulnerability. The vulnerable functionality exists in Tiptap's Markdown attribute parsing functionality. An attacker may provide specially crafted Markdown attribute strings that cause excessive regular-expression processing, potentially consuming significant CPU resources and causing the browser main thread, server event loop, or worker to become unresponsive. The affected version range is $\geq 3.7.0$ $< 3.30.5$.	
Evidence / Proof of Concept	
<pre>@tiptap/starter-kit@3.30.2 └─ @tiptap/core@3.30.2</pre>	
Impact	
Successful exploitation could cause excessive CPU consumption and make the application's browser main thread, server event loop, or worker unresponsive. In server-side Markdown processing, repeated malicious	

requests could consume processing resources and result in denial of service. Persisted malicious Markdown content could also repeatedly cause client-side freezing when processed.

Recommendation

Upgrade @tiptap/core to version 3.30.5 or higher.

VA-005 — Multiple Security Vulnerabilities in Nodemailer 9.0.5

Finding ID	VA-005
Severity	High
CVSS v4.0 Score	Score: 8.7 (High)
Assessment Type	SCA
Affected Asset / Component	nodemailer@9.0.5
CWE Reference	CWE-73 – External Control of File Name or Path (SSRF) CWE-436 – Interpretation Conflict CWE-407 – Inefficient Algorithmic Complexity CWE-436 – Interpretation Conflict
CVE Reference	N/A
Status	Open
Description	The application uses <code>nodemailer@9.0.5</code>, which is affected by four identified security vulnerabilities: Server-Side Request Forgery (SSRF), two separate Interpretation Conflict vulnerabilities, and Inefficient Algorithmic Complexity. These issues may allow attackers, depending on how Nodemailer is exposed and how user-controlled email content is processed, to access local resources or make outbound requests, bypass recipient/domain validation, or cause excessive CPU consumption that can disrupt email processing. The vulnerabilities are addressed by upgrading Nodemailer to version 9.1.1 or later.

Evidence / Proof of Concept

The installed package is nodemailer@9.0.5.

Impact

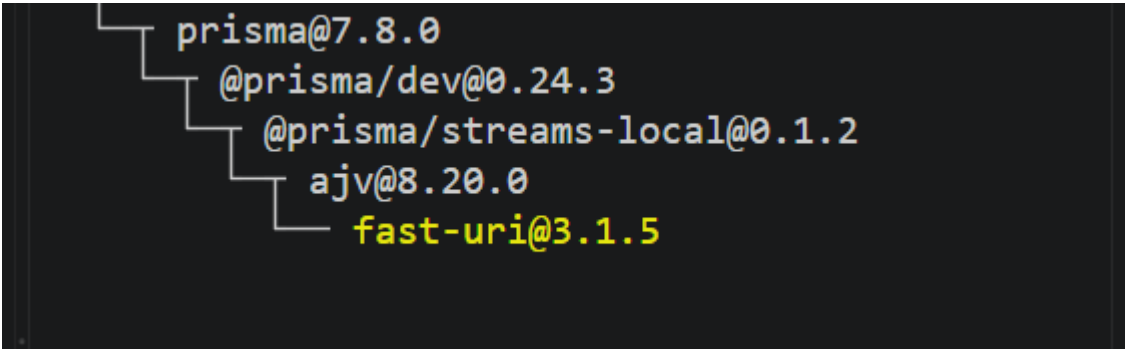
Depending on the application's use of Nodemailer and exposure of its email-processing functionality, successful exploitation could allow unauthorized outbound requests or access to local resources, cause emails to be delivered to unintended recipients by bypassing recipient validation, or consume excessive CPU resources and disrupt the Node.js event loop. These conditions may result in information disclosure, unauthorized email delivery, or denial of service.

Recommendation

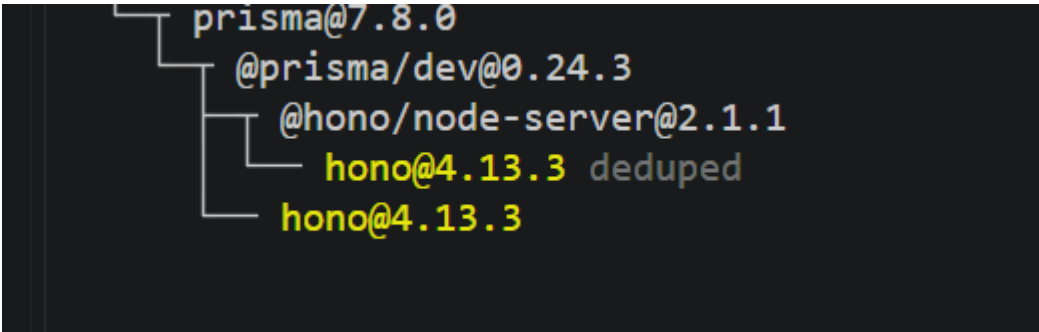
Upgrade nodemailer from version 9.0.5 to 9.1.1 or later. This upgrade addresses all four vulnerabilities identified in the current dependency.

VA-006 — Multiple Security Vulnerabilities in fast-uri 3.1.5

Finding ID	VA-006
Severity	High
CVSS v4.0 Score	Score: 8.7 (High)
Assessment Type	SCA
Affected Asset / Component	fast-uri@3.1.5 Dependency path: prisma@7.8.0 > @prisma/dev@0.24.3 > @prisma/streams-local@0.1.2 > ajv@8.20.0 > fast-uri@3.1.5
CWE Reference	CWE-436 – Interpretation Conflict CWE-174 – Double Decoding of the Same Data CWE-116 – Improper Encoding or Escaping of Output CWE associated with the remaining URI validation findings as applicable

CVE Reference	CVE-2026-75931 CVE-2026-75899 CVE-2026-84292
Status	Open
Description	The application includes fast-uri@3.1.5, which contains multiple high-severity vulnerabilities involving URI parsing, validation, decoding, and output handling. These weaknesses can cause security controls such as host allowlists, redirect validation, or SSRF protections to interpret a URI differently from the component that ultimately processes it. The affected package is introduced transitively through the Prisma dependency chain.
Evidence / Proof of Concept	
Impact	Successful exploitation may allow attackers to bypass URI-based security controls, redirect requests to unintended or attacker-controlled destinations, or potentially reach internal services such as localhost or cloud metadata endpoints where vulnerable URI handling is used for SSRF protection.
Recommendation	Upgrade the dependency chain to a version that resolves the vulnerable fast-uri release. For the 3.x branch, use fast-uri@3.1.7 or later.

VA-007 — Multiple Security Vulnerabilities in hono 4.13.3

Finding ID	VA-007
Severity	High
CVSS v4.0 Score	Score: 8.7 (High)
Assessment Type	SCA
Affected Asset / Component	hono@4.13.3
CWE Reference	CWE-444 – HTTP Request Smuggling CWE-405 – Asymmetric Resource Consumption Directory Traversal weakness associated with toSSG()
CVE Reference	CVE-2026-84365 CVE-2026-84363 CVE-2026-84364
Status	Open
Description	
The application uses hono@4.13.3, which is affected by multiple vulnerabilities including directory traversal, HTTP request smuggling, and asymmetric resource consumption. The vulnerabilities are fixed in hono@4.13.5 or later. The affected package is introduced transitively through Prisma.	
Evidence / Proof of Concept	
 <pre> prisma@7.8.0 ├── @prisma/dev@0.24.3 │ └── @hono/node-server@2.1.1 │ └── hono@4.13.3 deduped │ └── hono@4.13.3 </pre>	

Impact

Depending on how Hono functionality is used, exploitation may result in unauthorized file creation outside the intended build directory, bypass of security controls or cache poisoning through request smuggling, or denial of service through excessive memory consumption.

Recommendation

Upgrade hono to 4.13.5 or later.

VA-008 — Multiple Security Vulnerabilities in mysql2 3.15.3

Finding ID	VA-008
Severity	High
CVSS v4.0 Score	Score: 8.7 (High)
Assessment Type	SCA
Affected Asset / Component	mysql2@3.15.3
CWE Reference	CWE-522 – Insufficiently Protected Credentials CWE-409 – Improper Handling of Highly Compressed Data
CVE Reference	N/A
Status	Open

Description

The application includes mysql2@3.15.3, which is affected by vulnerabilities involving insufficient protection of database credentials and data amplification. The identified vulnerabilities are fixed in later versions of mysql2, with the required remediation target being 3.23.1 or later.

Evidence / Proof of Concept

Installed package version: mysql2@3.15.3

Impact

Exploitation may result in exposure of database credentials or denial of service through excessive memory consumption. The practical risk depends on the application's MySQL configuration, TLS usage, compression settings, and trust relationship with the database server.

Recommendation

Upgrade mysql2 to 3.23.1 or later, which addresses both identified vulnerabilities. Verify compatibility with the application's Prisma version and database configuration before deployment.

VA-009 — Multiple Security Vulnerabilities in sharp 0.35.3

Finding ID

VA-009

Severity

High

CVSS v4.0 Score

Score: 8.9 (High)

Assessment Type

SCA

Affected Asset / Component

sharp@0.35.3 Package

CWE Reference

CWE-122 – Heap-based Buffer Overflow

CVE Reference

N/A

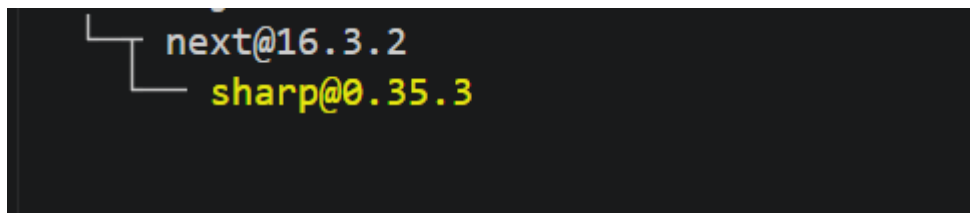
Status

Open

Description

The application uses sharp@0.35.3, which is vulnerable to a heap-based buffer overflow in the VipsForeignLoadHeif processing path. A specially crafted AVIF image may trigger the vulnerability and potentially result in arbitrary code execution. The vulnerability is fixed in sharp@0.35.4 or later.

Evidence / Proof of Concept



Impact

If the application processes attacker-controlled AVIF images, successful exploitation could cause application crashes, memory corruption, or potentially arbitrary code execution, resulting in compromise of the affected application process.

Recommendation

Upgrade sharp to 0.35.4 or later. Because the vulnerable package is introduced through next@16.3.2, also verify the dependency tree after upgrading Next.js to ensure that a fixed sharp version is actually installed.

VA-010 — Multiple Security Vulnerabilities in xlsx 0.20.3

Finding ID	VA-010
Severity	High
CVSS v4.0 Score	Score: 8.9 (High)
Assessment Type	SCA
Affected Asset / Component	xlsx@0.20.3 Package
CWE Reference	CWE-1321 – Improper Modification of Object Prototype Attributes (Prototype Pollution) CWE-1333 – Inefficient Regular Expression Complexity
CVE Reference	CVE-2023-30533 CVE-2024-22363
Status	Open

Description
The application uses the <code>xlsx</code> package, which has known vulnerabilities involving prototype pollution and Regular Expression Denial of Service (ReDoS) when processing specially crafted spreadsheet input.
Evidence / Proof of Concept
Installed package version: <code>xlsx@0.20.3</code>
Impact
If the application processes untrusted spreadsheet files, an attacker may be able to trigger prototype pollution or cause excessive CPU consumption leading to denial of service. The risk is significantly reduced if the application only generates/exports spreadsheets and does not parse arbitrary user-supplied spreadsheet files.
Recommendation
Do not rely solely on the currently installed npm-distributed <code>xlsx</code> package as a remediation. Evaluate replacing it with a maintained spreadsheet library or obtaining a security-fixed distribution from an authoritative source after validating its provenance and compatibility

VA-011 — Prototype Pollution in Tiptap Core	
Finding ID	VA-011
Severity	Medium
CVSS v4.0 Score	CVSS: 5.3 (Medium)
Assessment Type	SCA
Affected Asset / Component	@tiptap/core@3.30.2, introduced through @tiptap/starter-kit@3.30.2
CWE Reference	CWE-1321: Prototype Pollution
CVE Reference	N/A

Status	Open
Description	
The application uses @tiptap/core version 3.30.2, which has a known prototype pollution vulnerability. The vulnerable version is introduced as a transitive dependency through @tiptap/starter-kit version 3.30.2. Prototype pollution can allow an attacker to modify properties of JavaScript object prototypes under certain conditions, potentially affecting application behavior and, depending on the application's usage of the affected functionality, leading to security-impacting consequences.	
Evidence / Proof of Concept	
<pre>@tiptap/starter-kit@3.30.2 └─ @tiptap/core@3.30.2</pre>	
Impact	
Exploitation of prototype pollution may allow manipulation of inherited JavaScript object properties and could alter application logic or security controls that rely on affected objects. The actual impact depends on how Tiptap processes attacker-controlled input and how the vulnerable functionality is used within the application. Successful exploitation could potentially result in unauthorized behavior or other application-level security issues.	
Recommendation	
Upgrade @tiptap/core to version 3.30.4 or higher.	

VA-012 — Lack of Concurrent Session Management	
Finding ID	VA-012
Severity	Medium
CVSS v4.0 Score	CVSS: 4.8– Medium

Assessment Type	DAST
Affected Asset / Component	Session Management
CWE Reference	N/A
CVE Reference	N/A
Status	Open
Description	
The application allows a user account to maintain multiple active sessions simultaneously across different browsers or devices without restriction or notification.	
Evidence / Proof of Concept	
N/A	
Impact	
• Increased risk if credentials are compromised. • Unauthorized users may remain logged in even after the legitimate user signs in elsewhere. • Reduced visibility and control over active sessions. Provides unnecessary information about the application's infrastructure.	
Recommendation	
▪ Implement one or more of the following: ▪ Limit users to a single active session. ▪ Provide a log out from all devices feature. ▪ Display active sessions to users. ▪ Notify users when a new login occurs. ▪ Invalidate older sessions when a new session is established.	

VA-013 — Password Change Does Not Invalidate Existing Active Sessions

Finding ID	VA-013
Severity	Medium
CVSS v4.0 Score	CVSS: 5.8 – Medium,
Assessment Type	DAST
Affected Asset / Component	Authentication & Session Management Module
CWE Reference	CWE-613: Insufficient Session Expiration
CVE Reference	N/A
Status	Open
Description	
The application does not invalidate existing active sessions when a user changes their password. During testing, it was observed that after successfully updating the account password, previously authenticated sessions remained active and continued to have full access to the application without requiring re-authentication. This behavior indicates that session tokens are not revoked or refreshed upon credential change.	
Evidence / Proof of Concept	
Steps to Reproduce: 1. Log in to the application using a valid user account (Browser A). 2. Keep the session active without logging out. 3. Change the account password from the application settings. 4. Return to the previously logged-in session (Browser A). Observed Result: • Session remains active after password change.	

- No forced logout or session invalidation occurs.
- Existing session continues to function normally.

Impact

- If an attacker has an active session, they retain access even after password change.
- Password change does not fully revoke compromised access.
- Reduces effectiveness of credential recovery after compromise.
- Increases risk of persistent unauthorized access.
- Weakens overall session security model.

Recommendation

- Invalidate all active sessions when a user changes their password.
- Force re-authentication after credential updates.
- Rotate session identifiers upon password change.
- Maintain server-side session revocation tracking.
- Optionally notify users of all active sessions and allow manual session termination.

VA-014 — Weak Password Policy Allows Use of Commonly Used and Easily Guessable Passwords

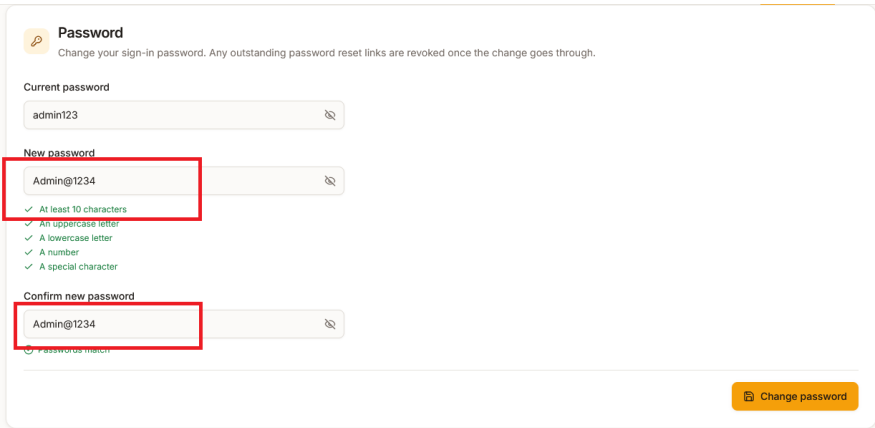
Finding ID	VA-014
Severity	Medium
CVSS v4.0 Score	CVSS: 5.1 – Medium
Assessment Type	DAST
Affected Asset / Component	User Account Management / Password Change Functionality
CWE Reference	CWE-521: Weak Password Requirements

CVE Reference	N/A
Status	Open

Description

The application enforces basic password complexity rules such as minimum length; however, it does not restrict the use of commonly used or easily guessable passwords. During testing, multiple weak and predictable passwords (e.g., “Test@123”, “Admin@123” and similar patterns) were accepted successfully during password change operations. This indicates that the system does not implement checks against commonly used, compromised, or easily guessable passwords, leaving user accounts vulnerable to credential-based attacks.

Evidence / Proof of Concept



Password
Change your sign-in password. Any outstanding password reset links are revoked once the change goes through.

Current password
admin123

New password
Admin@1234

- ✓ At least 10 characters
- ✓ An uppercase letter
- ✓ A lowercase letter
- ✓ A number
- ✓ A special character

Confirm new password
Admin@1234

Passwords match

Change password

Impact

- Increased risk of account compromise through credential stuffing attacks.
- Higher likelihood of successful password guessing using common password dictionaries.
- Reduced effectiveness of password-based authentication security.
- Potential non-compliance with modern security standards (e.g., NIST SP 800-63B recommendations).
- Exposure of user accounts to automated and large-scale attack tools.

Recommendation

- Implement a commonly used password block list using datasets of breached and weak passwords.
- Integrate password strength validation based on real-world entropy, not just length/complexity rules.
- Reject passwords found in known breach databases (e.g., HIBP-style checks).
- Prevent predictable patterns such as:
 - “Password123”
 - “CompanyName@123”
 - Sequential or keyboard-based patterns
- Provide real-time password strength feedback during password creation.
- Encourage passphrase-based passwords instead of complex but predictable patterns.

VA-015 — Weak Content Security Policy – unsafe-inline in style-src

Finding ID	VA-015
Severity	Low
CVSS v3.1 Score	CVSS: 3.1(low)
Assessment Type	DAST
Affected Asset / Component	https://vctestminiapp.nibbank.com.et/ — Content Security Policy configuration (style-src directive)
CWE Reference	CWE-693 – Protection Mechanism Failure
CVE Reference	N/A
Status	Open
Description	
The application's Content Security Policy (CSP) permits the use of inline CSS through the style-src 'unsafe-inline' directive. While the CSP provides several strong security controls, allowing inline styles weakens the	

Evidence / Proof of Concept

Impact

Allowing `'unsafe-inline'` weakens CSP's protection against certain forms of injected inline content and reduces the effectiveness of CSP as a defense-in-depth security control. If another client-side injection vulnerability exists, the weakened policy may provide less protection than a CSP that strictly restricts inline styles.

Recommendation

Remove 'unsafe-inline' from the style-src directive where technically feasible. Replace inline styles with external stylesheets or use CSP nonces/hashes for required inline styles.

6. Remediation Roadmap

6.1 Prioritized Remediation Table

Finding ID	Title	Severity	Owner	Discovery Date	Status
VA-001	Critical Security Vulnerabilities in Next.js 16.3.2	Critical	EPMO	10/9/2026	Open
VA-002	Multiple Security Vulnerabilities in Undici 7.29.0	Critical	EPMO	10/9/2026	Open
VA-003	Unrestricted File Upload via Double Extension Bypass	Critical	EPMO	16/09/2026	Solved
VA-004	Regular Expression Denial of Service (ReDoS) in Tiptap Core	High	EPMO	10/9/2026	Open
VA-005	Multiple Security Vulnerabilities in Nodemailer 9.0.5	High	EPMO	10/9/2026	Open
VA-006	Multiple Security Vulnerabilities in fast-uri 3.1.5	High	EPMO	10/9/2026	Open
VA-007	Multiple Security Vulnerabilities in hono 4.13.3	High	EPMO	10/9/2026	Open
VA-008	Multiple Security Vulnerabilities in mysql2 3.15.3	High	EPMO	10/9/2026	Open
VA-009	Heap-based Buffer Overflow in sharp 0.35.3	High	EPMO	10/09/2026	Open
VA-010	Multiple Security Vulnerabilities in xlsx 0.20.3	High	EPMO	10/09/2026	Open
VA-011	Prototype Pollution in Tiptap Core	Medium	EPMO	9/10/2026	Open
VA-012	Lack of Concurrent Session Management	Medium	EPMO	17/09/2026	Open
VA-013	Password Change Does Not Invalidate Existing Active Sessions	Medium	EPMO	16/06/2026	Open

Finding ID	Title	Severity	Owner	Discovery Date	Status
VA-014	Weak Password Policy Allows Use of Commonly Used and Easily Guessable Passwords	Medium	EPMO	16/09/2026	Open
VA-015	Weak Content Security Policy – unsafe-inline in style-src	Low	EPMO	17/09/2026	Open

6.2 Remediation Guidance (Risk-based)

Critical Severity

Critical findings represent vulnerabilities that may lead to full system compromise, unauthorized access, or severe data exposure. These issues require immediate attention and remediation as they pose unacceptable risk to business operations and security posture. Where immediate remediation is not feasible, compensating controls should be implemented to reduce exposure.

High Severity

High severity findings indicate significant security weaknesses that may allow unauthorized access, sensitive data exposure, or disruption of secure application functionality. These issues should be addressed as a priority before production deployment or exposure to untrusted environments.

Medium Severity

Medium severity findings represent security weaknesses that may be exploited under certain conditions or in combination with other vulnerabilities. These issues should be addressed as part of planned remediation cycles to strengthen overall application security and reduce attack surface.

Low Severity

Low severity findings represent security issues with limited individual impact and low likelihood of exploitation under normal conditions. While these issues do not pose an immediate or significant risk to the application, they may contribute to broader attack scenarios if combined with other weaknesses.

This category may include minor implementation flaws, weak configurations, informational security gaps, or deviations from recommended secure coding practices. Although exploitation is generally unlikely or low impact, remediation is recommended to reduce overall attack surface and improve the application's security maturity.

These findings should be addressed as part of the NIB's continuous security improvement process and standard development lifecycle practices.

7. Conclusion

The vulnerability assessment identified several security weaknesses within the Virtual Card solution, including three Critical and seven High severity findings that require immediate attention. The identified vulnerabilities expose the application to risks such as remote code execution, sensitive data exposure, account compromise, cryptographic bypass, and unauthorized access.

Although many of the findings are remediable through configuration changes, secure coding improvements, and dependency updates, failure to address these issues in a timely manner may significantly increase the organization's exposure to cyber threats, operational disruption, regulatory non-compliance, and reputational damage.

The assessment demonstrates the importance of implementing a mature and continuous application security program that incorporates:

- Secure software development practices
- Continuous vulnerability scanning
- Dependency management
- Security monitoring
- Regular security assessments

Timely remediation of the identified findings, combined with the recommended strategic security improvements, will significantly reduce the platform's attack surface and improve the overall resilience and security posture of the application environment.

A follow-up remediation validation and retest assessment is strongly recommended after all corrective actions have been implemented to verify the effective mitigation of the identified vulnerabilities. In addition, a comprehensive security assessment of the production environment, including the underlying infrastructure, servers, network components, and supporting services, should be conducted prior to go-live to ensure that no security weaknesses remain in the deployment architecture or operational environment.

Appendices

Appendix A: Glossary of Terms

Term	Definition
CVE	Common Vulnerabilities and Exposures — public catalog of known security flaws with unique identifiers
CWE	Common Weakness Enumeration — community-developed list of software and hardware weakness types
CVSS	Common Vulnerability Scoring System — standardized framework for rating the severity of vulnerabilities
SAST	Static Application Security Testing — automated analysis of source code or compiled binaries without execution
DAST	Dynamic Application Security Testing — automated testing of running applications to find runtime vulnerabilities
SCA	Software Composition Analysis — automated identification of vulnerable open-source and third-party components
IaC	Infrastructure as Code — managing and provisioning infrastructure through machine-readable configuration files
OWASP	Open Web Application Security Project — nonprofit foundation focused on improving software security
False Positive	A reported vulnerability that further investigation confirms does not actually exist
Zero-Day	A vulnerability unknown to the vendor with no available patch or mitigation at time of discovery
Compensating Control	An alternative security measure applied when a primary control cannot be implemented

Term	Definition
Attack Surface	The sum of all possible attack vectors through which an unauthorized user can attempt to gain access

Appendix B: CVSS v3.1 Scoring Reference

CVSS Score Range	Severity Rating	Color Indicator
9.0 – 10.0	Critical	Red
7.0 – 8.9	High	Orange
4.0 – 6.9	Medium	Yellow
0.1 – 3.9	Low	Green
0.0	Informational	Blue

Appendix C: Severity Classification Criteria

Severity	Classification Criteria
Critical	Remote unauthenticated code execution, authentication bypass leading to full compromise, direct and immediate risk of data breach, or CVSS score ≥ 9.0 .
High	Significant data exposure, unauthorized privilege escalation, high-impact exploitable weakness, or CVSS score between 7.0 and 8.9.
Medium	Limited exploitation scope requiring user interaction or specific preconditions, moderate data exposure risk, or CVSS score between 4.0 and 6.9.
Low	Minimal direct impact, provides limited information useful for further attacks, best-practice deviation, or CVSS score between 0.1 and 3.9.
Informational	Observations and best-practice recommendations with no direct security impact. CVSS score of 0.0.